

Advanced Security and Privacy

IT-Security Basis-Schutzmethoden in der Praxis

Grüner Pass

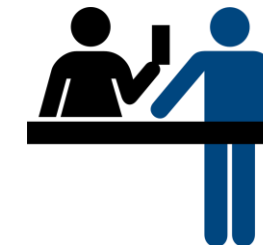
Dipl. Ing. Dr. Kevin Theuermann MSc

Agenda

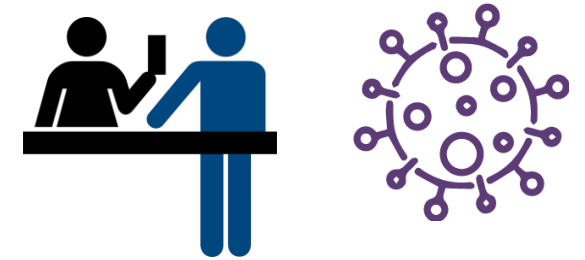
- Grüner Pass
 - Ausgangssituation
 - Anforderungen
 - Konzept und Implementierung
 - Sicherheitsbedenken
-

Ausgangssituation

- Im Februar 2020, erster Covid 19 Fall in Österreich
- Diverse Maßnahmen zur Eindämmung der Ausbreitungsgeschwindigkeit
- Wichtigste Maßnahme: 3G Regel
 - Geimpft
 - Genesen
 - Getestet
- Nachweis eines geringen epidemiologischen Risikos
- Statusnachweis über **digitale Zertifikate** auf Smartphones



Ausgangssituation



- Zertifikate müssen im Rahmen der Zutrittskontrollen verifiziert werden
- Interoperable Zertifikate sind erforderlich, um die freie Beweglichkeit in der EU zu gewährleisten
- EU-Mitgliedsstaaten müssen **Authentizität**, **Gültigkeit** und **Integrität** von Zertifikaten sicherstellen
- Erforderliche Regeln und Infrastruktur für eine zuverlässige und sichere Ausstellung und Verifizierung
- **Herausforderungen:**
 - Wie baut man einen gemeinsam gültigen Vertrauensrahmen auf?
 - Wie kann die Rückverfolgung von Bürgern verhindert werden, um die Privatsphäre zu schützen?
 - Wie kann man die Fälschung von Zertifikaten verhindern?

Agenda

- Grüner Pass
 - Ausgangssituation
 - Anforderungen
 - Konzept und Implementierung
 - Sicherheitsbedenken
-

Rechtliche Anforderungen| SARS-CoV-2 Zertifikate

Verordnung über die **EU Digital COVID Certificates**^[1] (1. Juli 2021)

- Für die Ausstellung der Zertifikate sind die nationalen Behörden zuständig
- Enthält einen QR-Code und eine digitale Signatur von einem **EU Gateway**

Aus Gründen der Datenminimierung sollten Zertifikate nur unbedingt erforderlichen personenbezogenen Daten enthalten



[1] EU Digital COVID Certificate: <https://eur-lex.europa.eu/legal-content/DE/TXT/PDF/?uri=CELEX:32021R0953&from=EN>

Rechtliche Anforderungen | Validatoren



- Identifizierung einer Person anhand eines amtlichen Lichtbildausweises
- Offline-Prüfung von Zertifikaten (Signaturprüfung)
 1. Überprüfung auf syntaktische und inhaltliche Korrektheit
 2. Überprüfung der zeitlichen Gültigkeit
- Elektronische Anwendungen zur Überprüfung von Zertifikaten (Validator-Apps)
 - Angegebene Zertifikatsdaten müssen eingeschränkt angezeigt werden (Vorname, Nachname, Geburtsdatum)
 - Bearbeitungen von Zertifikaten, die über die Verifizierung hinausgehen, sind unzulässig

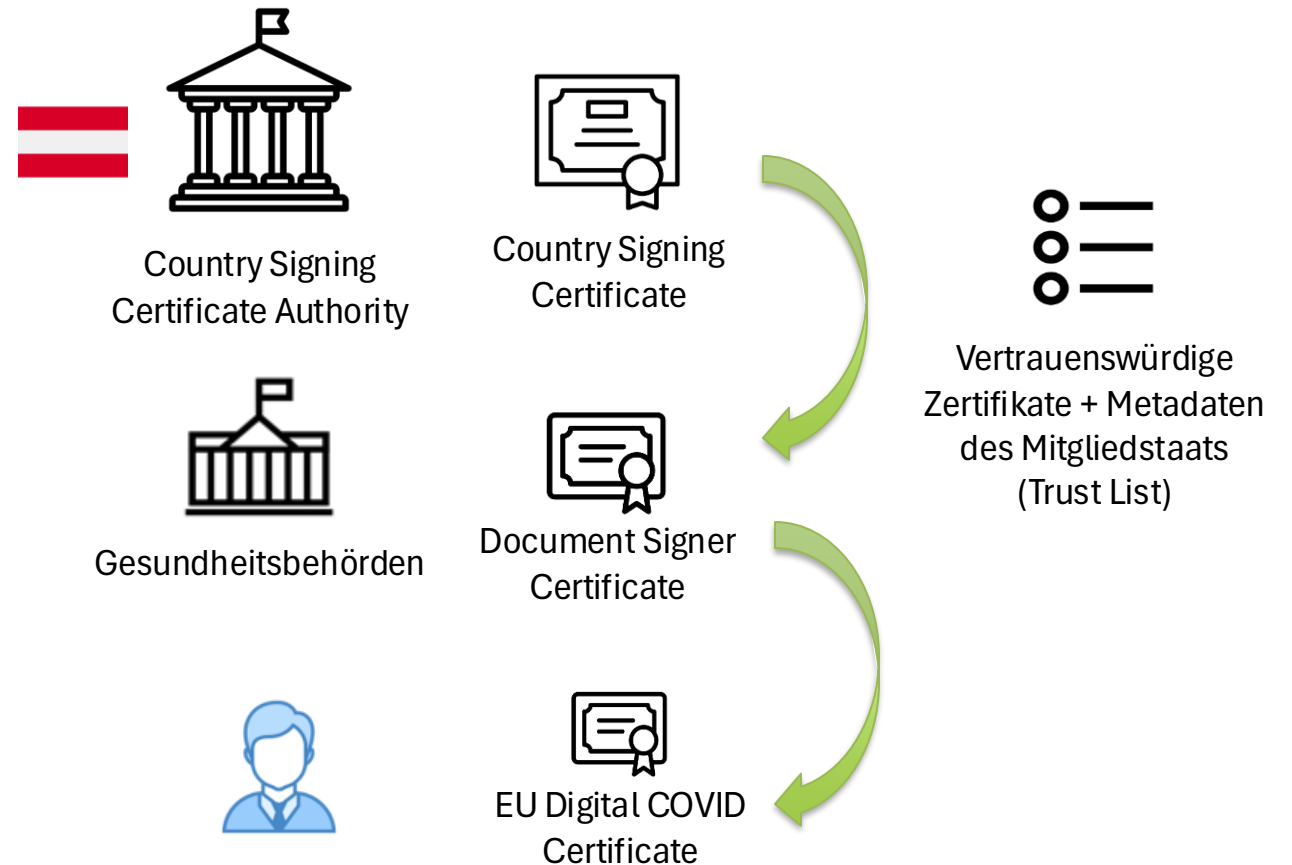
Verhindert die Rückverfolgbarkeit von Bürgern

Bewahrt die Privatsphäre der Bürger

Verhindert Missbrauch

Vertrauensmodell (Trust Model)

- **Country Signing Certificate Authority:** Die Country Signing Certificate Authority (CSCA) ist eine vertrauenswürdige Institution jedes teilnehmenden Landes, die für das Signieren der Dokumenten-Signaturzertifikate (DSC) zuständig ist.
- Die **Gesundheitsbehörden** stellen die EU Digital COVID Certificates aus und signiert sie mit dem Private Key des zugehörigen Document Signer Certificates
- Dadurch entsteht eine Verkettung der Zertifikate (Certificate Chain), die die Vertrauenswürdigkeit der ausgestellten Zertifikate gewährleistet
- Alle Country Signing Certificates und Document Signer Certificates sind öffentlich einsehbar und überprüfbar (**Trust List**)



Agenda

- Grüner Pass
 - Ausgangssituation
 - Anforderungen
 - Konzept und Implementierung
 - Sicherheitsbedenken
-

Digital Covid Certificate (DCC) Schema

- DCC stellt Daten im JSON Format dar (Schlüssel-Werte-Paare)
- Auf JSON basierendes Zertifikatschema zur Unterstützung der Serialisierung und Deserialisierung der DCC-Nutzdaten
- Schema unterstützt die Konformität mit der EU-Gesetzgebung in Bezug darauf, was in einem Zertifikat dargestellt werden soll

```
{
  "ver": "1.2.1",
  "nam": {
    "fn": "Musterfrau-G\u00f6\u00dfinger",
    "gn": "Gabriele",
    "fnt": "MUSTERFRAU<GOESSINGER",
    "gnt": "GABRIELE"
  },
  "dob": "1998-02-26",
  "v": [
    {
      "tg": "840539006",
      "vp": "1119349007",
      "mp": "EU/1/20/1528",
      "ma": "ORG-100030215",
      "dn": 1,
      "sd": 2,
      "dt": "2021-02-18",
      "co": "AT",
      "is": "Ministry of Health, Austria",
      "ci": "URN:UVC:01:AT:10807843F94AEE0EE5093FBC254BD813#B"
    }
  ]
}
```

EU eHealthNetwork Digital COVID Certificate Value Sets^[1]

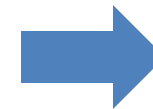
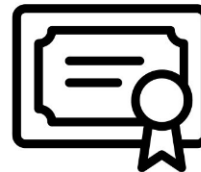
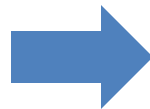
- **Value Sets** bieten eine Zuordnung zwischen Rohdaten und "vom Menschen lesbaren" Daten und werden vom JSON Schema referenziert
- QR-Code enthält Rohdaten
- Zum Beispiel:
- EU/1/20/1528 verweist auf „Comirnaty“ (Impfstoff von Biontech/Pfizer)
- ORG-100030215 verweist auf „BioNTechManufacturing GmbH“
- Value Sets Repository wird regelmäßig aktualisiert
- Rohdaten, werden für die Durchsetzung von „Business Rules“ (Regeln) verwendet

```
{
  "ver": "1.2.1",
  "nam": {
    "fn": "Musterfrau-G\u00f6\u00dfinger",
    "gn": "Gabriele",
    "fnt": "MUSTERFRAU<GOESSINGER",
    "gnt": "GABRIELE"
  },
  "dob": "1998-02-26",
  "v": [
    {
      "tg": "840539006",
      "vp": "1119349007",
      "mp": "EU/1/20/1528",
      "ma": "ORG-100030215",
      "dn": 1,
      "sd": 2,
      "dt": "2021-02-18",
      "co": "AT",
      "is": "Ministry of Health, Austria",
      "ci": "URN:UVCI:01:AT:10807843F94AEE0EE5093FBC254BD813#B"
    }
  ]
}
```

Digital COVID Certificates: Business Rules

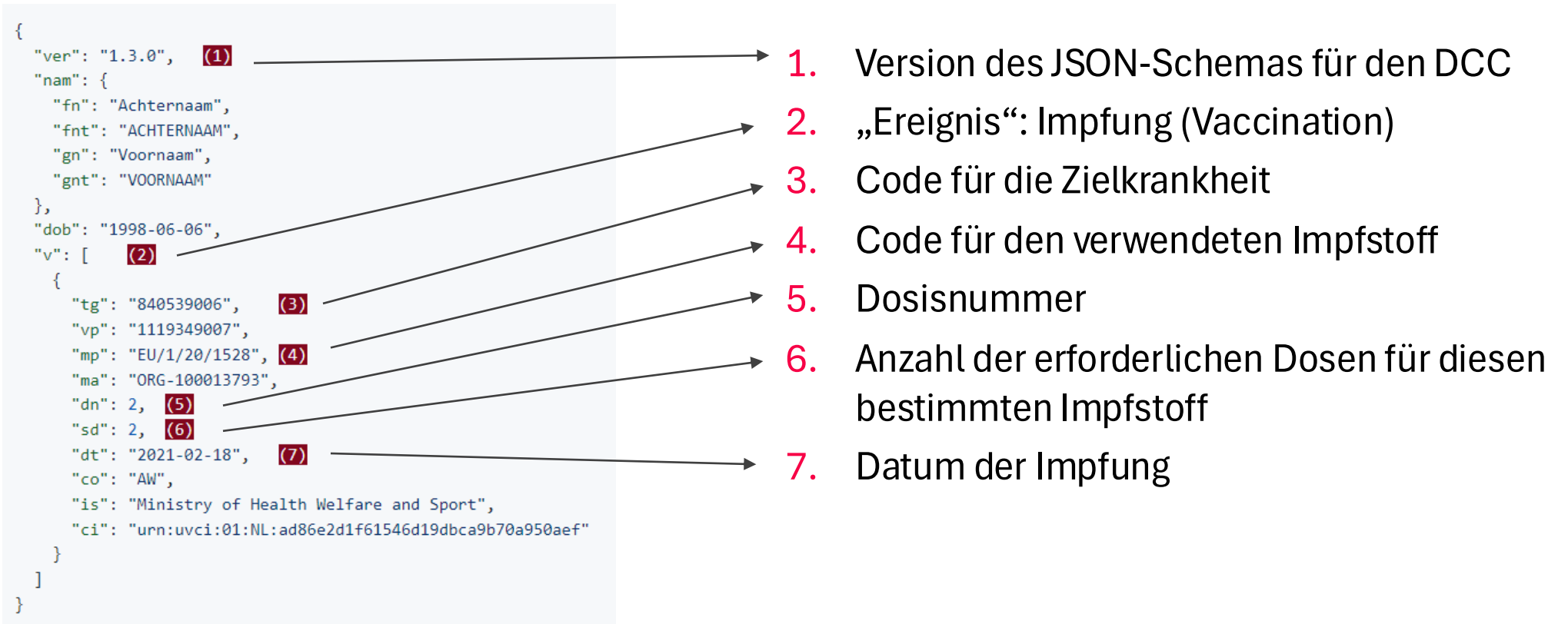
- Business Rules stellen die Verifizierungslogik in Validierungs-Apps dar
- EU-DCC-Validierungsregeln werden auf den Payload der Zertifikate angewandt
- Länder können die Business Rules adaptieren, die bestimmen ob ein Zertifikat gültig ist, oder nicht

GREEN PASS



Digital COVID Certificates: Business Rules

Beispiel: Zweite Impfung mit BioNTech/Pfizer COVID-19-Impfstoff



Digital COVID Certificates: Business Rules

Es müssen mindestens folgende Daten verifiziert werden:

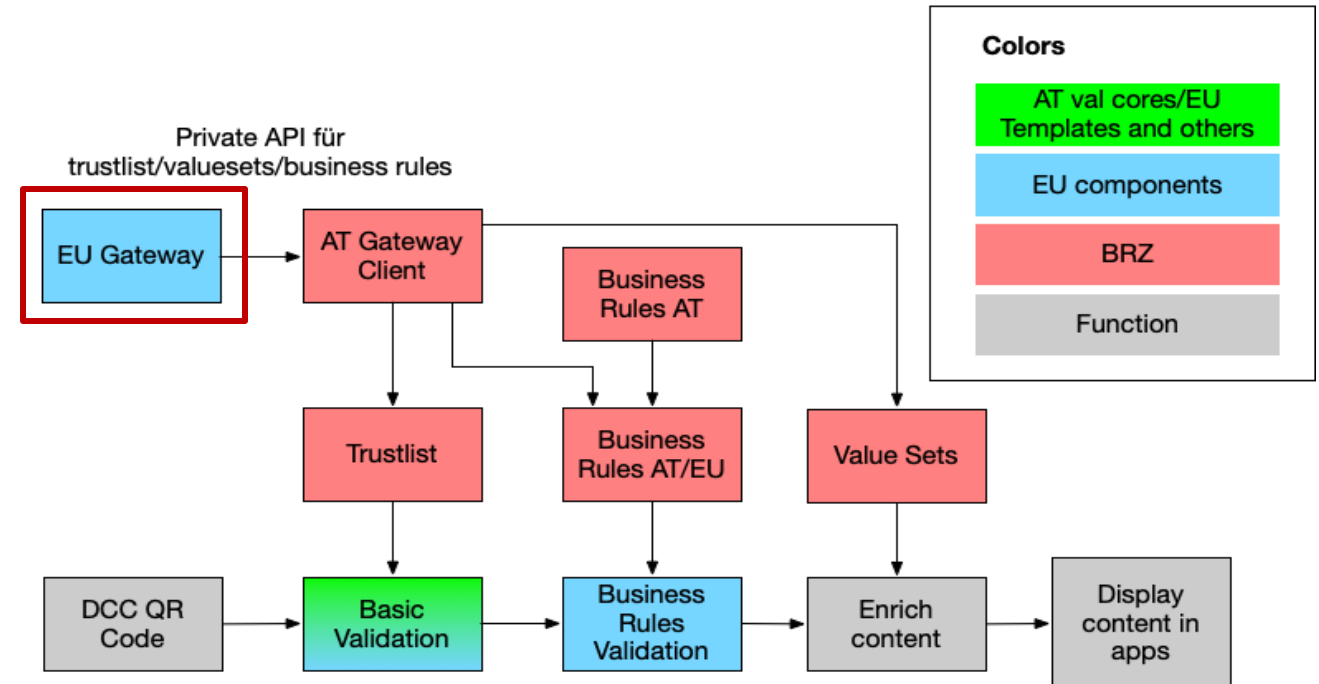
```
{
  "ver": "1.3.0", (1)
  "nam": {
    "fn": "Achternaam",
    "fnt": "ACHTERNAAM",
    "gn": "Voornaam",
    "gnt": "VOORNAAM"
  },
  "dob": "1998-06-06",
  "v": [ (2)
    {
      "tg": "840539006", (3)
      "vp": "1119349007",
      "mp": "EU/1/20/1528", (4)
      "ma": "ORG-100013793",
      "dn": 2, (5)
      "sd": 2, (6)
      "dt": "2021-02-18", (7)
      "co": "AW",
      "is": "Ministry of Health Welfare and Sport",
      "ci": "urn:uvci:01:NL:ad86e2d1f61546d19dbca9b70a950aef"
    }
  ]
}
```

- Code für die Zielkrankheit
(COVID19?)
- Code für den verwendeten Impfstoff
(von der European Medicine Agency EMA zugelassen?)
- Dosisnummer
(ausreichend?)
- Datum der Impfung
(vor 14 Tagen / nicht länger als 365 Tage?)

Österreichische Architektur

EU Gateway

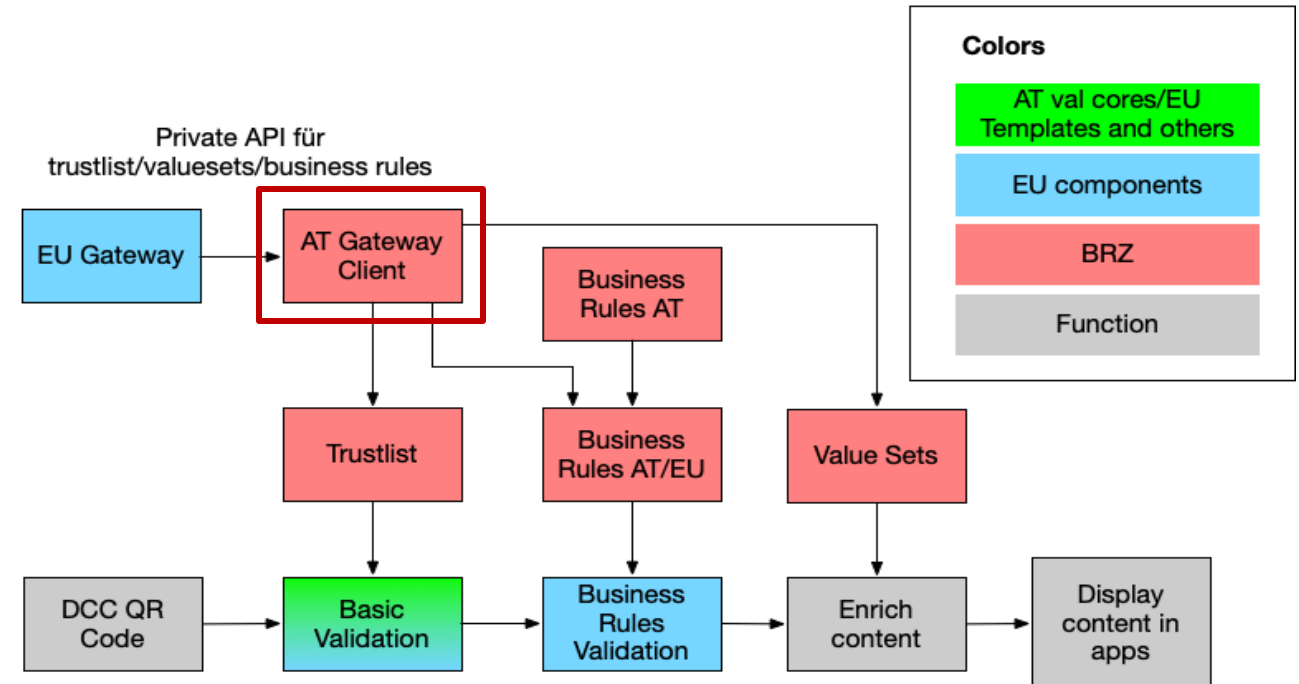
- Von der EU betriebenes zentrales Gateway
- Verteilt Informationen an die Mitgliedsstaaten:
 - Trust List (Liste aller vertrauenswürdigen Zertifikate)
 - Business Rules (Nationale und globale Regeln)
 - Value Sets (Bedeutung der Datenfelder im Zertifikat)
- Zugang zum Gateway **nicht öffentlich** → erfordert authentifizierte Verbindungen von Backend-Diensten in EU-Mitgliedsstaaten



Österreichische Architektur

AT Gateway Client

- Der österreichische Backend-Client stellt eine authentifizierte Verbindung zum EU-Gateway her, um Informationen abzurufen
- Informationen werden über österreichische Dienste verarbeitet und verbreitet, die vom Bundesrechenzentrum (BRZ) betrieben werden



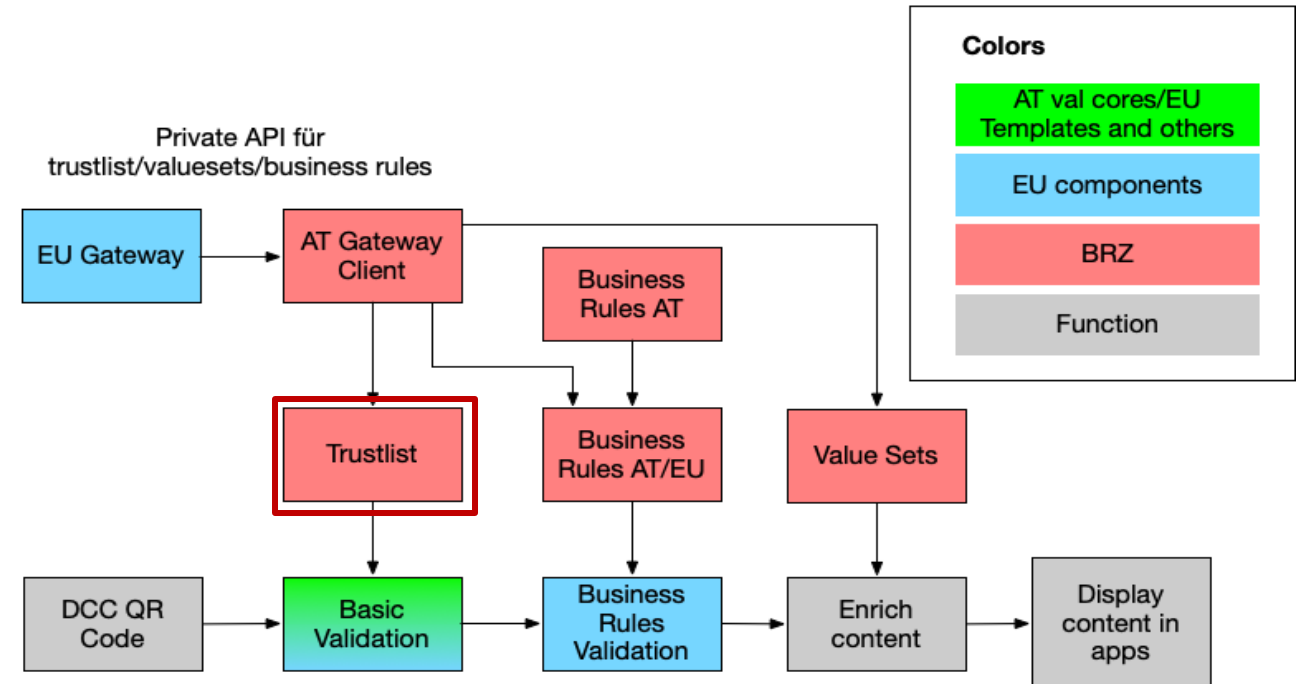
Österreichische Architektur

AT Gateway Client

Erstellt stündlich die folgenden Dateien:

1. Trust List:

- Enthält alle Document Signer Certificates (DSC)
- Diese Signaturzertifikate werden benötigt, um die Gültigkeit und Authentizität von digitalen Signaturen zu validieren, die über QR-Codes präsentiert werden



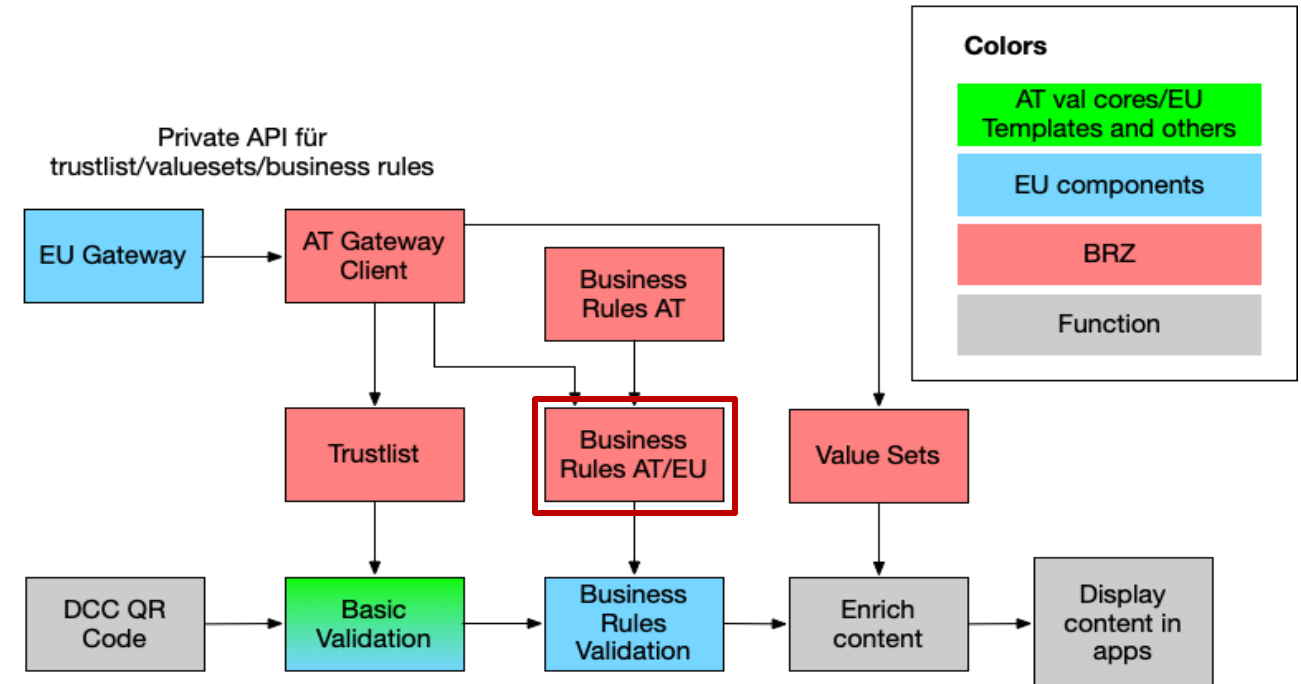
Österreichische Architektur

AT Gateway Client

Erstellt stündlich die folgenden Dateien:

2. Business Rules AT/EU:

- **EU:** Rechtsvorschriften der verschiedenen Mitgliedsstaaten, anhand derer die Gültigkeit der DCCs bei der Einreise in ein bestimmtes Land überprüft wird (festgelegtes Ablaufdatum von Zertifikaten usw.)
- **AT:** Nationale Regeln für Validierungs-Apps



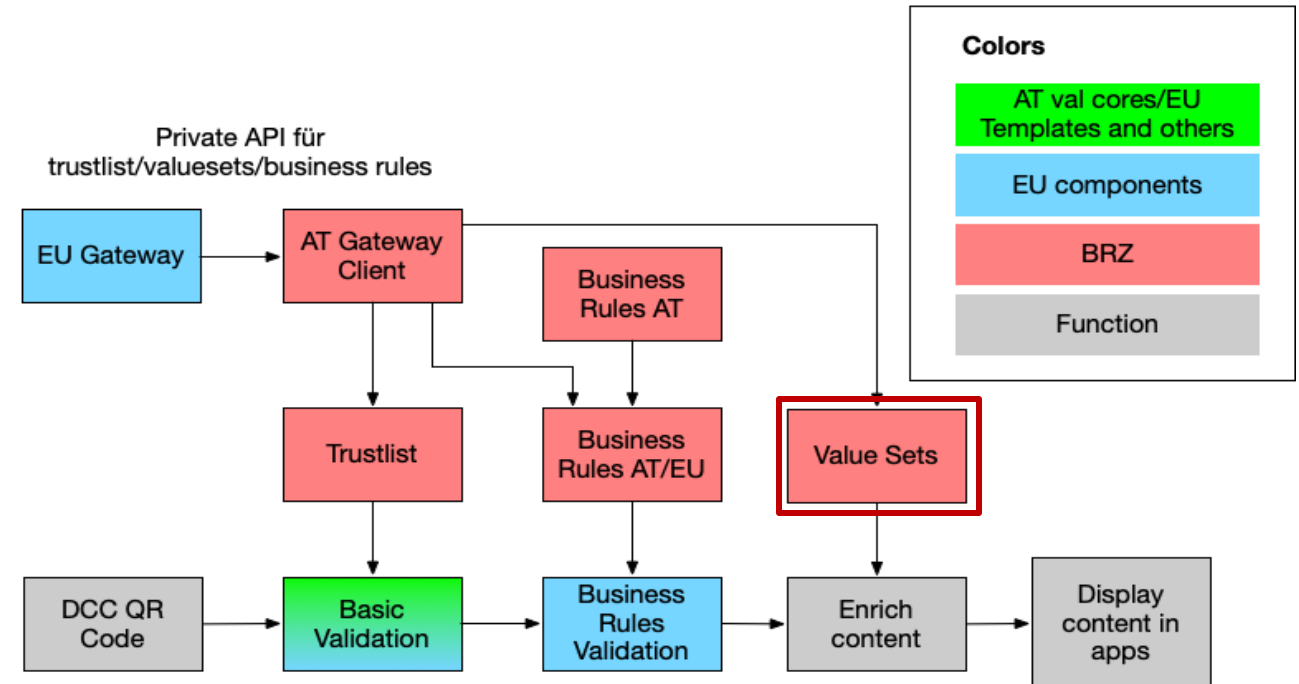
Österreichische Architektur

AT Gateway Client

Erstellt stündlich die folgenden Dateien:

3. Value Sets:

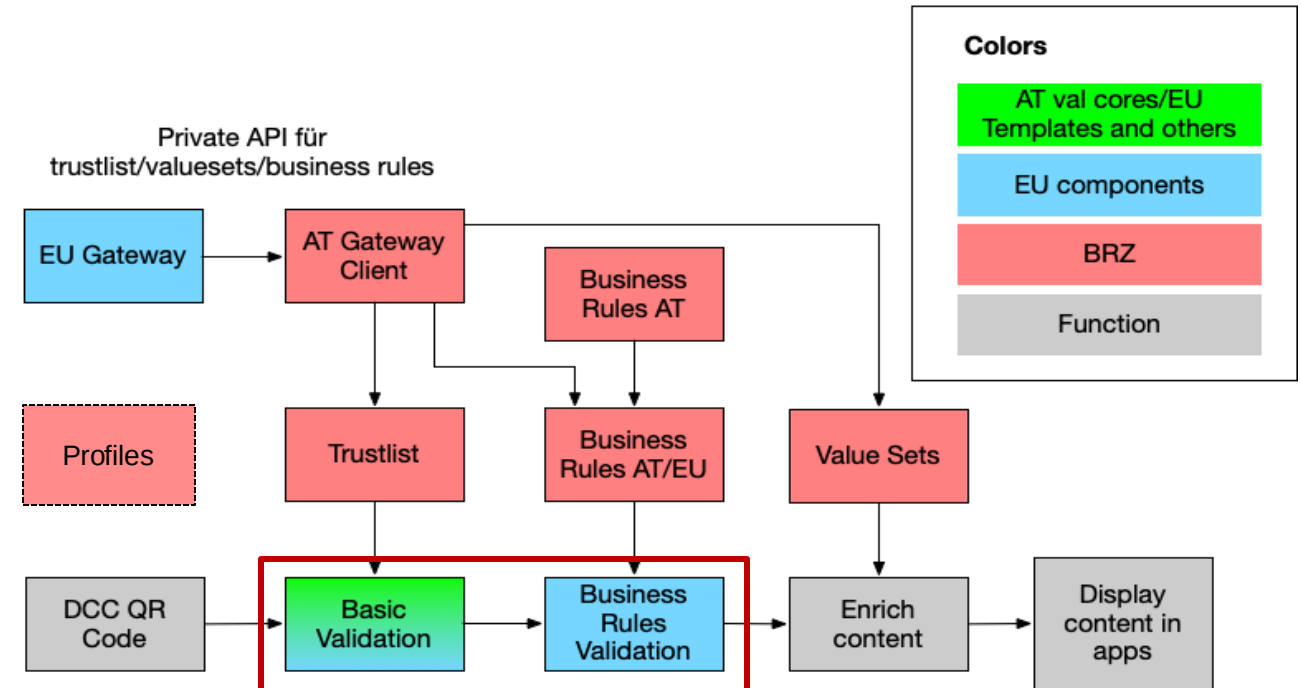
- Informationen zur Zuordnung von Rohwerten zu menschenlesbaren Werten
- Value Sets werden aktuell gehalten



Österreichische Architektur

EU Komponenten:

- **Basic Validation:** Validierungskomponente zur Überprüfung der strukturellen Korrektheit und Authentizität eines DCC
- **Business Rules Validation:** Komponente zur Validierung der Business Rules gegenüber einem DCC (erlaubte Impfungen, wie lange ein bestimmter Test als gültig angesehen wird usw.)
 - z.B.: Gültigkeit des PCR-Tests in Österreich = 48h
 - z.B.: Pfizer-Impfstoff für 1 Jahr akzeptiert



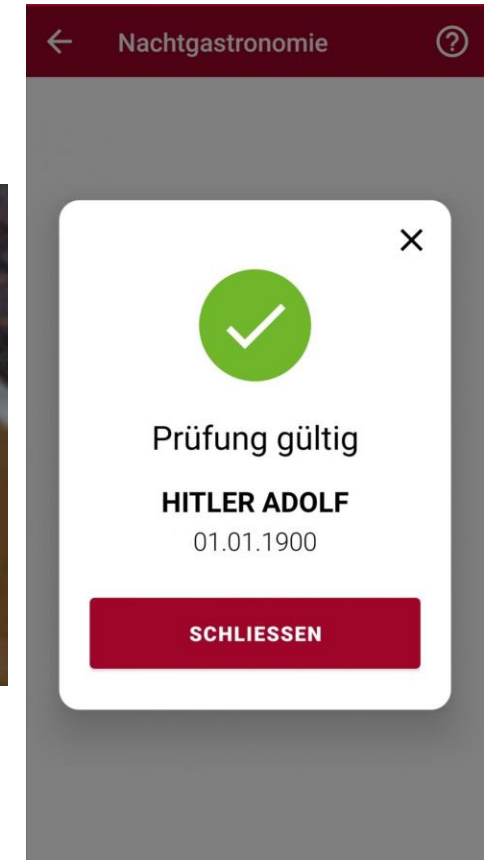
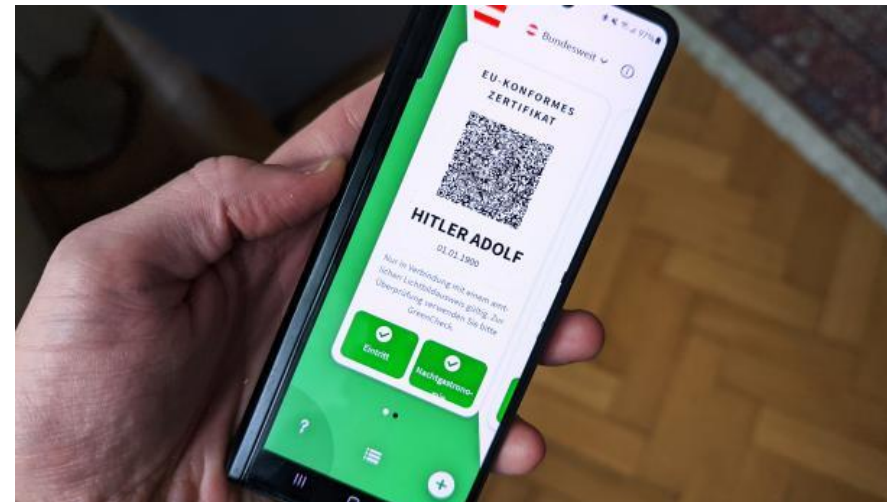
Agenda

- Grüner Pass
 - Ausgangssituation
 - Anforderungen
 - Konzept und Implementierung
 - Sicherheitsbedenken
-

Sicherheitsbedenken

Der Standard^[1] veröffentlicht im November 2021:

- Gefälschte Impfausweise werden in Validierungs-Apps als gültig anerkannt
- Urkunde von Adolf Hitler wurde mit verschiedenen Geburtsdaten akzeptiert
- Das Zertifikat hatte eine gültige Unterschrift der französischen Sozialversicherungsbehörde CNAM
- Es besteht die Gefahr, dass mehrere gefälschte Zertifikate im Umlauf sind

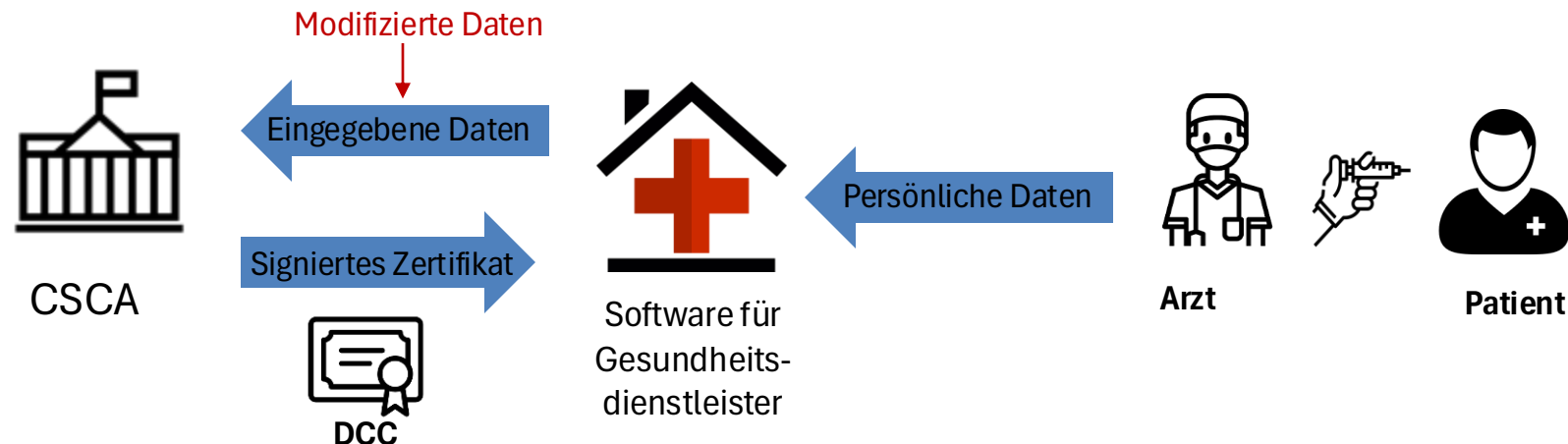


[1] Standard: <https://www.derstandard.at/story/2000131078659/gruener-pass-app-bleibt-unsicher-hitler-zertifikate-funktionieren-weiterhin>

Sicherheitsbedenken

Beispiel-Implementierung - Erstellung digitaler COVID-Zertifikate (HCERT):

1. Nach der Impfung gibt der Arzt persönliche Daten in seine Software ein
 2. Die eingegebenen Daten werden an die Country Signing Certificate Authority (CSCA) übermittelt, die ein gültiges Zertifikat ausstellt
- Wenn die Software des Gesundheitsdienstleisters kompromittiert wurde, könnten eingegebene Daten (z. B. Name einer Person) geändert werden
 - Theoretisch können Ärzte für jede beliebige Person ein Attest erstellen
 - Es gibt viele verschiedene Implementierungen von Software zum Auslösen der Erstellung von Digital Covid Certificates (DCC)



Offene Probleme

Unsachgemäße Verwendung von QR-Codes:

- Jeder, dem ein QR-Code zum Scannen gezeigt wird, könnte möglicherweise ein Foto des QR-Codes machen
- Mit diesem Foto kann der Green Pass ohne Wissen der ursprünglich zugeteilten Person einfach nachgebaut werden

Daher:

- Im Zuge von z.B. Eingangstests ist die Identität einer Person zusätzlich per Lichtbildausweis nachzuweisen
- Der Benutzer der Validierungs-App ist für die Identitätsprüfung verantwortlich
- Option: Dänemark reduziert die Gültigkeit von QR-Codes auf 3 Tage



Advanced Security and Privacy

IT-Security Basis-Schutzmethoden in der Praxis

Grüner Pass

Dipl. Ing. Dr. Kevin Theuermann MSc